LAPORAN FINAL PROJECT

Software Security

Threat Modelling dan Analisis Keamanan pada Platform E-Commerce

Kelompok 3

NIM	Nama
2802496691	Andhika Permana Sagiyono
2802396373	Darren Gavriel Suntara
2802438754	Nathasa Bintang Kayesa
2802487592	Michael Ernst Jeremy Octama
2802498085	Sebastian Chang

BAB I — Pendahuluan

1.1 Latar Belakang

Pesatnya perkembangan teknologi digital telah mengubah lanskap industri perdagangan dari konvensional menjadi berbasis elektronik (e-commerce). Aplikasi e-commerce saat ini mengintegrasikan berbagai fitur kompleks mulai dari manajemen promo, pencarian produk, sistem pembayaran instan, hingga metode pembayaran di tempat atau Cash on Delivery (COD). Kompleksitas integrasi fitur ini berbanding lurus dengan meningkatnya permukaan serangan (attack surface) yang dapat dieksploitasi oleh aktor ancaman.

Analisis keamanan sangat krusial karena aplikasi e-commerce menangani data sensitif pengguna, kredensial akun, serta transaksi finansial secara real-time. Kebocoran data atau eksploitasi pada fitur pembayaran tidak hanya berdampak pada kerugian materiil bagi platform dan pengguna, tetapi juga dapat menurunkan reputasi serta kepercayaan publik secara permanen. Oleh karena itu, diperlukan sebuah pendekatan pemodelan ancaman (threat modeling) yang proaktif untuk mengidentifikasi, mengategorikan, dan memitigasi celah keamanan sebelum dieksploitasi di lingkungan produksi.

1.2 Tujuan

Tujuan dari analisis keamanan ini adalah sebagai berikut:

- Mengidentifikasi fitur-fitur utama dan sensitif pada aplikasi E-commerce (Payment, Search Bar, Promo, Login/Register, dan COD).
- Menganalisis potensi ancaman keamanan pada setiap fitur tersebut dengan menggunakan kerangka kerja STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege).
- Memetakan setiap ancaman spesifik ke dalam pola serangan standar industri berdasarkan taksonomi CAPEC (Common Attack Pattern Enumeration and Classification) dan OWASP.
- Merancang strategi mitigasi yang aplikatif dan efektif (seperti Address, Transfer, Accept) untuk setiap ancaman yang ditemukan.
- Melakukan pemodelan ancaman terstruktur menggunakan komponen Data Flow Diagram (DFD) dan matriks STRIDE.
- Menganalisis trade-off atau titik keseimbangan antara implementasi kontrol keamanan dengan performa sistem serta kenyamanan pengguna (usability).

1.3 Ruang Lingkup

Analisis keamanan dalam laporan ini dibatasi pada batas-batas (boundaries) berikut:

Fitur yang Dicakup:

- Sistem Payment (Pembayaran): Berfokus pada proses pertukaran pesan API, integritas data transaksi (manipulasi kupon/nilai data), dan perlindungan konkurensi (kondisi race condition).
- Search Bar (Kolom Pencarian): Berfokus pada validasi input terhadap serangan siber berbasis teks seperti SQL Injection, Reflected Cross-Site Scripting (XSS), serta eksploitasi memori server (Denial of Service melalui query kompleks).
- Manajemen Promo: Berfokus pada penyalahgunaan hak promo melalui serangan impersonation (phishing via chat) dan otomatisasi request massal (DDoS/Spam request).
- Autentikasi (Login & Register): Berfokus pada proteksi kredensial, manipulasi state pengguna, brute force, serta integritas log aktivitas untuk mencegah pemalsuan catatan.
- Sistem COD (Cash on Delivery): Berfokus pada aspek non-repudiasi (non-repudiation) yang melibatkan akun palsu, penggunaan perangkat bersama (shared device), dan kelemahan pencatatan sistem (weak logging).

Fitur yang Tidak Dicakup:

- Keamanan infrastruktur fisik server, manajemen jaringan internal (seperti konfigurasi routing hardware), keamanan supply chain pihak ketiga (misalnya driver logistik eksternal), serta kepatuhan regulasi hukum (seperti GDPR atau PCI-DSS) secara menyeluruh. Hal ini tidak dicakup karena analisis difokuskan pada arsitektur logika aplikasi dan celah pada level software framework.

1.4 Metode

Laporan ini disusun dengan menggunakan metodologi terstruktur sebagai berikut:

- STRIDE Framework: Digunakan sebagai dasar kategorisasi ancaman guna memastikan seluruh aspek keamanan (Autentikasi, Integritas, Akuntabilitas, Kerahasiaan, Ketersediaan, dan Otorisasi) dianalisis secara menyeluruh pada setiap fungsi aplikasi.
- CAPEC & OWASP Reference: Menyelaraskan skenario serangan nyata yang ditemukan (seperti CAPEC-94, CAPEC-26, CAPEC-66, CAPEC-591, CAPEC-469, CAPEC-151, CAPEC-112, CAPEC-74, CAPEC-93, CAPEC-16, dan OWASP A09) untuk memahami execution flow dari tahap Explore, Experiment, hingga Exploit.
- Data Flow Diagram (DFD): Memetakan aliran data antar-aktor, proses, data store, dan entitas eksternal dalam aplikasi e-commerce untuk mengidentifikasi trust boundaries yang rentan.
- Trade-off Analysis: Melakukan evaluasi mendalam terhadap dampak mitigasi yang diusulkan. Analisis ini menimbang apakah mitigasi tersebut akan membebani latensi server, memperumit user

experience (misalnya penggunaan CAPTCHA/MFA berlebih), atau membutuhkan biaya infrastruktur tambahan.

BAB II — Gambaran Umum Aplikasi

2.1 Deskripsi Aplikasi

Aplikasi ini adalah platform perdagangan berbasis elektronik (*e-commerce*) modern yang dirancang untuk menjembatani penjual dan pembeli secara digital. Platform ini mengintegrasikan berbagai fitur transaksional yang kompleks dan dinamis dengan fokus utama pada security-first approach untuk melindungi seluruh ekosistem digital dari berbagai ancaman cyber.

1. Tujuan Aplikasi

- **Fasilitasi e-commerce Modern:** Menyediakan ekosistem belanja online yang mulus, cepat, dan responsif, mulai dari pencarian produk hingga pembayaran.
- **Keamanan Transaksi & Data:** Menjamin kerahasiaan (*confidentiality*), integritas (*integrity*), dan ketersediaan (*availability*) data sensitif pengguna, informasi finansial, serta kredensial akun dari ancaman eksploitasi.
- **Fleksibilitas Pembayaran:** Menyediakan opsi pembayaran yang inklusif dan variatif (instan maupun COD) tanpa mengorbankan validitas dan keamanan proses validasi transaksi.
- **Pencegahan Risiko Finansial & Reputasi:** Menggunakan pendekatan pemodelan ancaman (*threat modeling*) proaktif untuk mendeteksi celah keamanan (seperti manipulasi promo atau *fraud* pembayaran) guna menjaga reputasi platform dan kepercayaan publik.

2. Target Pengguna

Aplikasi ini dirancang untuk melayani ekosistem pengguna yang heterogen, antara lain:

- **Pembeli (Consumers):** Masyarakat umum yang menginginkan pengalaman belanja praktis, mencari promo, dan membutuhkan metode pembayaran yang fleksibel (transfer bank, *e-wallet*, maupun COD) dengan jaminan keamanan data pribadi.
- **Penjual (Merchants/Vendors):** Pelaku usaha (UMKM hingga *brand* besar) yang memerlukan lapak digital aman untuk mengelola inventaris produk, memproses pesanan, dan menerima pencairan dana penjualan secara *real-time*.
- **Administrator & Tim Keamanan (Ops/Security Team):** Pengelola platform yang bertanggung jawab memantau transaksi, mengelola manajemen promo, serta melakukan analisis keamanan dan mitigasi celah secara berkala.

3. Platform yang Digunakan

Untuk menjangkau pasar yang luas dan memberikan fleksibilitas akses, aplikasi ini berjalan secara **Multi-Platform (Cross-Platform)**:

- **Web Application:** Ditujukan untuk akses universal melalui peramban (*browser*) pada komputer maupun perangkat bergerak, ideal untuk manajemen toko yang intensif oleh penjual dan penjelajahan produk yang detail oleh pembeli.
- **Mobile Application (Android & iOS):** Dioptimalkan untuk memberikan pengalaman belanja yang lebih personal, mendukung notifikasi instan (untuk promo dan status pengiriman), serta integrasi keamanan biometrik (seperti *fingerprint* atau *face ID*) saat transaksi.

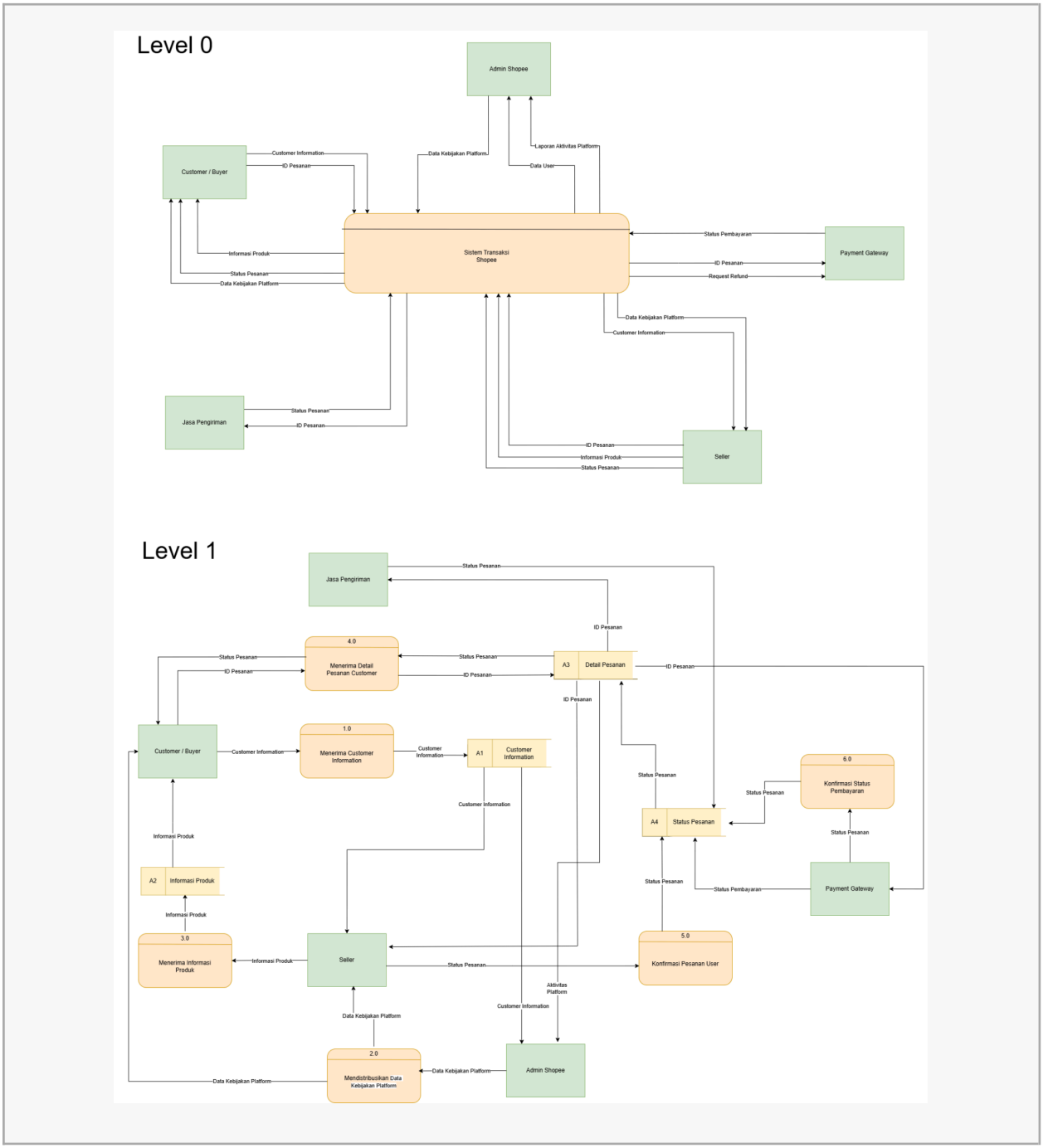
2.2 Daftar Fitur

No	Nama Fitur	Deskripsi Singkat
1	Login / Register	Merupakan fitur yang harus ada di sistem ecommerce, dimana pengguna baik buyer maupun seller bisa melakukan login dan register ke akun mereka sehingga sistem bisa mengenali mereka. Begitu juga dengan admin yang memiliki akses lebih daripada user biasa.
2	Search Bar	Fitur yang juga harus ada di sistem ecommerce untuk melakukan pencarian suatu barang yang diinginkan
3	Payment	Fitur inti yang memungkinkan buyer melakukan transaksi barang dan seller mendapatkan hasil penjualan barang mereka
4	Promo	Fitur yang memungkinkan para buyer mendapatkan voucher potongan harga yang bisa mereka gunakan saat membeli barang.
5	COD	Fitur yang memungkinkan buyer melakukan transaksi secara tunai lewat kurir saat pesanan mereka tiba di lokasi.

BAB III - Threat Model

Data Flow Diagram (DFD)

Data Flow Diagram (DFD) digunakan sebagai salah satu metode pemodelan sistem untuk mendukung proses security analysis pada aplikasi e-commerce. Diagram ini membantu mengidentifikasi komponen yang terlibat dalam pengolahan data, hubungan antar komponen, serta perpindahan data yang terjadi selama proses transaksi. Dengan memahami aliran data dan batas kepercayaan (trust boundary), potensi ancaman keamanan dapat dianalisis secara lebih sistematis menggunakan pendekatan threat modeling. Adapun data flow diagram tersebut bisa diakses melalui *link* berikut.



Adapun komponen-komponen yang terdapat pada data flow diagram diatas berupa :

- Entitas Eksternal

  Entitas eksternal adalah pihak-pihak di luar sistem yang berinteraksi langsung dengan Sistem Transaksi E-commerce:

  - Customer/Buyer

    Pengguna utama platform yang mengirimkan Customer Information (data registrasi/login) dan menerima output berupa Informasi Produk, Status Pesanan, dan Data Kebijakan Platform. Customer juga mengirim dan menerima ID Pesanan terkait transaksi yang sedang berjalan.
  - Seller

    Pihak penjual yang menyediakan Informasi Produk ke sistem dan menerima ID Pesanan, Informasi Produk, serta Status Pesanan dari sistem sebagai notifikasi transaksi.
  - Admin E-Commerce Sebagai pengelola platform

    Pengelola platform yang menerima Laporan Aktivitas Platform dan Data User dari sistem, serta mengirimkan Data Kebijakan Platform untuk diproses dan didistribusikan ke seluruh entitas.
  - Payment Gateway sebagai layanan pihak ketiga yang memproses pembayaran

    Sistem pembayaran eksternal yang menerima ID Pesanan dan Request Refund dari sistem, lalu mengembalikan Status Pembayaran sebagai konfirmasi transaksi.
  - Jasa Pengiriman

    Mitra logistik yang menerima ID Pesanan dari sistem dan mengirimkan kembali Status Pesanan (update pengiriman) ke sistem.
- Proses Utama Aplikasi

  Pada Level 1, sistem dipecah menjadi 6 proses utama:

No	Proses	Fungsi
1.0	Menerima Customer Information	Menerima dan memvalidasi data pelanggan (registrasi/login)
2.0	Mendistribusikan Data Kebijakan Platform	Menyebarkan kebijakan dari Admin E-Commerce ke seluruh aktor
3.0	Menerima Informasi Produk	Memproses data produk yang dikirimkan oleh Seller
4.0	Menerima Detail Pesanan Customer	Mengelola data pesanan yang dibuat oleh Customer/Buyer

5.0	Konfirmasi Pesanan User	Mengonfirmasi detail pesanan kepada pengguna
6.0	Konfirmasi Status Pembayaran	Memproses dan mengonfirmasi hasil pembayaran dari Payment Gateway
7.0	Memproses Pengantaran Pesanan	Mengelola aliran data antara sistem dan Jasa Pengiriman untuk memproses pengiriman fisik barang kepada Customer

- Data Store

  Data store adalah penyimpanan data internal yang digunakan oleh proses-proses dalam sistem:

Data Store	Deskripsi
A1 Customer Information	Menyimpan data pelanggan yang diterima dari proses 1.0. Data ini digunakan kembali oleh proses lain seperti proses distribusi kebijakan dan konfirmasi pesanan.
A2 Informasi Produk	Menyimpan katalog produk dari Seller. Data ini diakses oleh proses 3.0 untuk diteruskan ke Customer/Buyer.
A3 Detail Pesanan	Menyimpan rincian transaksi pesanan. Data store ini menjadi pusat rujukan antara proses 4.0 (penerimaan pesanan), proses 5.0 (konfirmasi), proses 7.0 (pengantaran), dan entitas Jasa Pengiriman. ID Pesanan yang tersimpan di A3 menjadi kunci identifikasi yang dikirim ke Jasa Pengiriman.
A4 Status Pesanan	Menyimpan kondisi terkini setiap pesanan. Data ini diperbarui oleh proses 6.0 berdasarkan Status Pembayaran dari Payment Gateway, dan juga diperbarui oleh proses 7.0 berdasarkan Status Pesanan yang diterima kembali dari Jasa Pengiriman.

- Aliran Data

  Aliran data menggambarkan pergerakan informasi antar entitas, proses, dan data store:

  - Customer → Proses 1.0 → A1: Data registrasi/login pelanggan disimpan di store Customer Information.
  - Admin E-Commerce → Proses 2.0 → Seller/Customer: Kebijakan platform didistribusikan ke semua aktor terkait.

- Seller ⟶ Proses 3.0 ⟶ A2 ⟶ Customer: Informasi produk dari Seller diproses dan diteruskan ke Customer.
- Customer ⟶ Proses 4.0 ⟶ A3: Pesanan yang dibuat Customer disimpan ke store Detail Pesanan.
- A3 ⟶ Proses 5.0 ⟶ Customer: Detail pesanan dikonfirmasi kembali ke pengguna.
- Payment Gateway ⟶ Proses 6.0 ⟶ A4: Status pembayaran diproses dan status pesanan diperbarui.
- A3 ⟶ Proses 7.0 ⟶ Jasa Pengiriman: ID Pesanan dikirim ke Jasa Pengiriman untuk memulai proses pengiriman fisik.
- Jasa Pengiriman ⟶ Proses 7.0 ⟶ A4: Status Pesanan hasil pembaruan dari Jasa Pengiriman diterima, diproses, lalu disimpan ke A4 dan diteruskan ke Customer.

Identifikasi Aset Kritis

No	Aset	Kategori	Lokasi di DFD	Tingkat Kekritisan	Deskripsi
1	Customer Information	Data	A1 / Proses 1.0	Sangat Tinggi	Data pribadi pengguna mencakup kredensial login dan informasi akun; rentan terhadap SQL Injection, Brute Force, dan Session Hijacking
2	Detail Pesanan	Data	A3 / Proses 4.0, 5.0	Sangat Tinggi	Rekaman transaksi lengkap yang mencakup ID pesanan, produk, dan harga; bila dimanipulasi dapat menyebabkan kerugian finansial pada Customer dan Seller
3	Status Pesanan	Data	A4 / Proses 6.0, 7.0	Tinggi	Kondisi real-time pesanan dari pembayaran hingga pengiriman; rentan dimanipulasi melalui eksploitasi sistem log yang lemah terutama pada transaksi COD
4	Status Pembayaran	Data	Proses 6.0 ↔ Payment Gateway	Sangat Tinggi	Data konfirmasi finansial dari Payment Gateway; rentan terhadap Race Condition dan

					Bypass Validasi Client Side yang dapat mengakibatkan transaksi tidak sah
5	Informasi Produk	Data	A2 / Proses 3.0	Tinggi	Data katalog produk dari Seller yang diakses melalui Search Bar; rentan terhadap SQL Injection dan Reflected XSS melalui input query pencarian
6	Data Kebijakan Platform	Data	Proses 2.0 ↔ Admin E-Commerce	Tinggi	Aturan operasional yang didistribusikan ke seluruh aktor termasuk data promo; bila dimanipulasi oleh bot atau akun palsu berdampak sistemik pada seluruh pengguna
7	Session dan Cookie Pengguna	Data	Proses 1.0 ↔ Customer	Tinggi	Data sesi aktif pengguna yang digunakan untuk mempertahankan status login; rentan terhadap manipulasi user state dan eksploitasi pada shared device
8	Proses Autentikasi	Proses	Proses 1.0	Sangat Tinggi	TinggiTitik masuk utama sistem yang memproses login dan registrasi; rentan terhadap SQL Injection, Brute Force, dan manipulasi session/cookie
9	Proses Konfirmasi Pembayaran	Proses	Proses 6.0	Sangat Tinggi	Proses paling kritis secara finansial yang memvalidasi transaksi; rentan terhadap Race Condition, Bypass Validasi Client Side, dan manipulasi status transaksi
10	Proses Penerimaan Pesanan	Proses	Proses 4.0	Tinggi	Proses yang mengelola data pesanan dari Customer; rentan terhadap penggunaan akun palsu terutama pada metode pembayaran COD

11	Proses Pengantaran Pesanan	Proses	Proses 7.0	Tinggi	Proses yang mengelola komunikasi dengan Jasa Pengiriman; rentan terhadap eksploitasi sistem log yang lemah dan penggunaan akun palsu pada transaksi COD
12	Proses Penerimaan Informasi Produk	Proses	Proses 3.0	Sedang	Proses yang menangani query pencarian produk dari Customer; rentan terhadap SQL Injection, Reflected XSS, dan Denial of Service melalui query pencarian berat
13	Mekanisme Distribusi Kebijakan	Proses	Proses 2.0	Tinggi	Proses distribusi kebijakan dan informasi promo dari Admin E-Commerce; rentan terhadap penyerangan bot dan akun palsu yang menyebarkan phishing promo
14	Sumber Daya Server	Layanan	Proses 3.0	Sedang	Kapasitas CPU dan memori server yang melayani query pencarian; rentan terhadap Denial of Service melalui query pencarian berat yang membebani sistem
15	Sistem Log Transaksi	Layanan	A3, A4 / Proses 7.0	Tinggi	Catatan aktivitas transaksi terutama COD; sistem log yang lemah dapat dieksploitasi untuk menyembunyikan aktivitas mencurigakan atau manipulasi data pesanan

Trust Boundary

Berdasarkan Data Flow Diagram yang telah dibuat, terdapat beberapa batas kepercayaan (trust boundary) yang memisahkan zona dengan tingkat kepercayaan berbeda dalam Sistem Transaksi E-Commerce. Setiap batas kepercayaan merepresentasikan titik kritis di mana data berpindah dari satu zona ke zona lain, sehingga memerlukan mekanisme keamanan yang tepat untuk mencegah akses tidak sah maupun manipulasi data. Identifikasi trust boundary ini dilakukan dengan mengacu

pada aliran data antar entitas eksternal, proses internal, dan data store yang terdapat pada DFD Level 0 dan Level 1. Berikut adalah tabel identifikasi trust boundary pada sistem:

No	Batas Kepercayaan	Komponen yang Dipisahkan
TB-1	Customer/Buyer ↔ Sistem	Entitas Customer/Buyer dengan Proses 1.0 (Menerima Customer Information) dan Proses 4.0 (Menerima Detail Pesanan Customer)
TB-2	Seller ↔ Sistem	Entitas Seller dengan Proses 3.0 (Menerima Informasi Produk) dan Proses 2.0 (Mendistribusikan Data Kebijakan Platform)
TB-3	Admin E-Commerce ↔ Sistem	Entitas Admin E-Commerce dengan Proses 2.0 (Mendistribusikan Data Kebijakan Platform)
TB-4	Payment Gateway ↔ Sistem	Entitas Payment Gateway dengan Proses 6.0 (Konfirmasi Status Pembayaran)
TB-5	Jasa Pengiriman ↔ Sistem	Entitas Jasa Pengiriman dengan Proses 7.0 (Memproses Pengantaran Pesanan)
TB-6	Zona Proses Internal ↔ Data Store	Proses 1.0, 3.0, 4.0, 5.0, 6.0, 7.0 dengan Data Store A1 (Customer Information), A2 (Informasi Produk), A3 (Detail Pesanan), dan A4 (Status Pesanan)

BAB IV — Analisis Ancaman per Fitur

A. Fitur: Payment

Nama Fitur	Payment
Deskripsi	Memfasilitasi proses perhitungan tagihan dan transaksi pembayaran dalam aplikasi e-commerce.
Aktor Terkait	User (Penyerang) / Sistem / Payment Gateway

Ancaman 1: Manipulasi status kupon

STRIDE Analysis:

STRIDE	*Tampering*

Bagaimana Attack dapat Terjadi

Penyerang memposisikan diri di tengah komunikasi jaringan antara aplikasi klien (browser/mobile app) dan server e-commerce. Penyerang mencegat paket data (*request* atau *response*) saat proses *checkout* dan memodifikasi parameter yang terkait dengan kupon diskon. Tujuannya adalah untuk memanipulasi validitas kupon (misalnya membuat kupon kedaluwarsa menjadi valid) atau mengubah nilai potongan harga secara sepihak, sehingga penyerang membayar jauh lebih murah dari yang seharusnya.

Prasyarat (Prerequisite)

- Aplikasi mengandalkan perhitungan harga akhir atau validasi kupon di sisi klien (*client-side*).
- Server tidak melakukan validasi ulang (*re-validation*) yang ketat terhadap jumlah tagihan akhir sebelum meneruskannya ke *payment gateway*.
- Tidak ada pengamanan integritas data *payload* (seperti *signature/HMAC*) pada jalur komunikasi HTTP/API.

Sumber Daya yang Dibutuhkan Penyerang

Alat *proxy* jaringan (seperti Burp Suite, OWASP ZAP, atau aplikasi *packet sniffer*) yang memungkinkan penyerang untuk menahan (*intercept*) dan mengubah data HTTPS di perangkat mereka sendiri sebelum diteruskan ke server.

Konsekuensi / Dampak

Scope	Impact	Likelihood
Integrity	Attacker dapat menggunakan Kupon promo berkali kali hingga harga barang menjadi sangat murah bahkan 0	Probable

Mapping Standard References:

CAPEC ID	*CAPEC-94 Adversary in the Middle (MitM)*

Kenapa Berkaitan

Ancaman ini terjadi karena penyerang memposisikan diri di tengah pertukaran data (sebagai proxy) untuk memodifikasi pesan sebelum mencapai tujuannya (server).

Alur Eksekusi Serangan

1. Explore (Reconnaissance)

Penyerang menentukan mekanisme komunikasi antara aplikasi dan server dengan melakukan serangan *sniffing* untuk mengamati protokol komunikasi yang digunakan.

2. Experiment

Penyerang memposisikan dirinya sebagai *routing proxy* di antara target. Penyerang mengeksploitasi kelemahan dalam komunikasi terenkripsi (seperti SSL usang) atau menginstal *spyware* untuk mencegat paket.

3. Exploit

Penyerang secara aktif mencegat, membaca, memfilter, atau mengubah muatan data yang dilewatkan di antara kedua belah pihak yang sedang berkomunikasi tanpa disadari oleh keduanya.

Mitigasi

Cara Mitigasi

Mengimplementasikan Server-Side Validation mutlak. Server mengabaikan data total harga atau nilai diskon yang dikirim dari klien, dan menghitung ulang total belanja secara mandiri berdasarkan ID produk dan ID kupon yang ada di Database.

Kenapa Mitigasi Mengurangi Risk

Menggeser kepercayaan (trust) murni ke sisi server. Sekalipun penyerang memanipulasi payload di perjalanan, server tidak akan memprosesnya karena kalkulasi akhirnya akan terbukti tidak match dengan perhitungan internal server.

Pendekatan	*Address*

Ancaman 2: Eksploitasi Race Condition

STRIDE Analysis:

STRIDE	*Tampering, Denial of Service*

Bagaimana Attack dapat Terjadi

Serangan ini terjadi ketika sistem memproses beberapa permintaan pembayaran atau klaim kupon secara bersamaan tanpa mekanisme antrian yang aman. Penyerang mengeksploitasi *time gap* antara saat sistem mengecek saldo/kuota promo dan saat sistem memotong saldo tersebut. Akibatnya, satu kupon diskon bisa dipakai berkali-kali dalam satu detik, atau penyerang bisa membeli barang berkali-kali walau saldonya hanya cukup untuk satu barang.

Prasyarat (Prerequisite)

- Terdapat sumber daya yang diakses dan dimodifikasi oleh beberapa proses secara bersamaan.
- Sistem tidak memiliki mekanisme penguncian atau sinkronisasi pemrosesan transaksi yang ketat.

Sumber Daya yang Dibutuhkan Penyerang

Akses yang sah ke fitur pembayaran dan *tools* otomasi jaringan (seperti Burp Suite Intruder, Postman, atau *script* Python kustom) yang mampu mengirimkan puluhan *request* HTTP secara serentak dalam satuan milidetik.

Konsekuensi / Dampak

Scope	Impact	Likelihood
Integrity / Availability	Attacker dapat menggunakan saldo yang dimiliki untuk membeli barang lebih dari jumlah yang sebenarnya	Probable

Mapping Standard References:

CAPEC ID	*CAPEC-26 Leveraging Race Conditions*

Kenapa Berkaitan

Ancaman ini secara spesifik mengeksploitasi celah waktu (*timing window*) antara tahap pengecekan (*Time of Check*) dan tahap penggunaan (*Time of Use*) pada suatu sumber daya yang sama, yang merupakan inti dari definisi *Race Condition*.

Alur Eksekusi Serangan

1. Explore (Reconnaissance)

Penyerang mengidentifikasi sumber daya bersama (*shared resources*) di dalam sistem, seperti file, variabel, atau database, yang dapat diakses secara paralel oleh beberapa proses atau *thread*.

2. Experiment

Penyerang menguji seberapa besar jendela waktu (*timing window*) antara saat sistem mengecek status sumber daya (Time of Check) dan saat sistem mengeksekusi penggunaan sumber daya tersebut (Time of Use).

3. Exploit

Penyerang memicu eksekusi *multi-thread* atau beberapa proses secara bersamaan pada waktu yang sangat presisi untuk memanipulasi status sumber daya sesaat sebelum sistem selesai menguncinya, sehingga membelokkan alur eksekusi aplikasi dari yang seharusnya.

Mitigasi

Cara Mitigasi

- Menerapkan *Pessimistic/Optimistic Locking* saat memproses saldo/kupon.
- Menggunakan antrian pemrosesan transaksi berurutan (*message broker* seperti RabbitMQ/Kafka).

Kenapa Mitigasi Mengurangi Risk

Mekanisme *locking* memastikan bahwa ketika satu transaksi sedang memproses kuota atau saldo pengguna, baris data tersebut "dikunci". Jika ada *request* lain masuk secara bersamaan, *request* tersebut dipaksa menunggu hingga transaksi pertama selesai, sehingga mencegah terjadinya klaim atau pemotongan ganda.

Pendekatan	*Address*

Ancaman 3: Bypass Validasi Client Side

STRIDE Analysis:

STRIDE	*Tampering*

Bagaimana Attack dapat Terjadi

Penyerang memanipulasi data keranjang belanja atau format input sebelum dikirim ke server. Karena aplikasi terlalu mempercayai validasi keamanan yang hanya ada di sisi antarmuka (*client-side* seperti pembatasan JavaScript atau HTML), penyerang dapat menghapus hambatan tersebut di browser mereka. Mereka kemudian memodifikasi harga barang menjadi lebih murah atau mengubah tipe produk yang tidak sesuai aturan bisnis, lalu mengirimkannya ke *server*.

Prasyarat (Prerequisite)

- Validasi harga, status produk, atau total tagihan hanya diterapkan di sisi *front-end* (browser/aplikasi mobile).
- Server (Back-end) menerima *request* dari klien dan langsung memprosesnya ke database tanpa melakukan validasi ulang.

Sumber Daya yang Dibutuhkan Penyerang

Alat bawaan web (*Browser Developer Tools* / *Inspect Element*) atau alat proxy (Burp Suite) yang memungkinkan penyerang mencegat dan mengedit permintaan HTML/JS sebelum meluncur ke server.

Konsekuensi / Dampak

Scope	Impact	Likelihood
Integrity	Attacker bisa merubah harga barang, stok barang, bahkan logika serta parameter sensitif lain nya melalui intercepting	Probable

Mapping Standard References:

CAPEC ID	*CAPEC-207 Removing Client-Side Security Constraints*

Kenapa Berkaitan

Ancaman ini langsung merujuk pada taktik penyerang yang menonaktifkan, menghapus, atau memanipulasi kontrol keamanan yang disematkan pada antarmuka klien untuk memaksa server mengeksekusi data yang telah dimodifikasi.

Alur Eksekusi Serangan

1. Explore (Reconnaissance)

Penyerang berinteraksi dengan aplikasi web dan memeriksa kode sisi klien (HTML, JavaScript) untuk memetakan batasan input atau filter keamanan yang ada.

2. Experiment

Penyerang menguji bagaimana aplikasi bereaksi apabila elemen pembatasan keamanan klien tersebut diubah nilainya, dihapus atributnya (seperti `disabled`, `readonly`, atau `maxlength`), atau dikelabuhi via proxy.

3. Exploit

Penyerang mengirimkan *request* yang berisi data kotor atau muatan di luar batas yang seharusnya ditolak oleh klien. Server memproses input ini tanpa curiga karena berasumsi data tersebut sudah melewati penyaringan klien yang sah.

Mitigasi

Cara Mitigasi

- Menduplikasikan setiap pemeriksaan keamanan dan logika bisnis yang ada di klien ke sisi server (*Strict Server-Side Validation*).
- Membatasi pengiriman parameter harga dari klien; klien hanya mengirimkan `ProductID` dan `Quantity`, sementara harga diambil langsung dari Database.

Kenapa Mitigasi Mengurangi Risk

Memposisikan server sebagai *single source of truth*. Sekalipun pengguna berhasil meretas tampilan antarmukanya dan mengirimkan harga palsu, transaksi akan digagalkan oleh server karena sistem akan mencocokkan harga tersebut dengan data murni yang ada di *backend/database* sebelum pembayaran disetujui.

Pendekatan	*Address*

B. Fitur: Search Bar

Nama Fitur	Search Bar
Deskripsi	Pencarian yang memfasilitasi pengguna untuk menemukan produk, toko, atau item di dalam aplikasi e-commerce.
Aktor Terkait	User / Penyerang

Ancaman 1: SQL Injection pada Search Bar

STRIDE Analysis:

STRIDE	*Tampering, Information Disclosure, Elevation of Privilege*

Bagaimana Attack dapat Terjadi

Serangan ini mengeksploitasi sistem *backend* yang menyusun pernyataan kueri database (SQL) secara langsung dari teks yang diketik pengguna di *search bar*. Karena aplikasi gagal menyaring karakter khusus, penyerang dapat mengetikkan sintaks manipulatif. Hal ini menyebabkan kueri SQL melakukan tindakan di luar dari sekadar mencari barang, melainkan mengekstrak data sensitif.

Prasyarat (Prerequisite)

Aplikasi (Web Server) menerima input dari pengguna dan langsung menggabungkannya ke dalam *string* kueri database tanpa proses validasi, sanitasi, atau parameterisasi yang memadai.

Sumber Daya yang Dibutuhkan Penyerang

Browser web standar. Untuk serangan lanjutan, penyerang bisa menggunakan alat bantu seperti proksi penangkap lalu lintas web (WireShark, Burp Suite) atau *tools* otomasi eksploitasi SQL seperti SQLMap.

Konsekuensi / Dampak

Scope	Impact	Likelihood
Confidentiality / Integrity	Attacker dapat memanipulasi query Database. Sehingga attacker bisa melihat data sensitif, mengubah isi database, atau bahkan menghapus table.	Probable

Mapping Standard References:

CAPEC ID	*CAPEC-66 SQL Injection*

Kenapa Berkaitan

Ancaman ini secara harfiah merupakan bentuk injeksi SQL, di mana data dari sumber yang tidak tepercaya (input pencarian *user*) dikirim ke database dan dieksekusi sebagai perintah alih-alih data biasa.

Alur Eksekusi Serangan

1. Explore (Reconnaissance)

Penyerang memetakan (spidering) situs web untuk menemukan semua titik masuk (*entry points*) yang mengumpulkan input dari pengguna, seperti formulir pencarian, parameter URL, atau header HTTP tertentu.

2. Experiment

Penyerang mencoba memasukkan karakter khusus SQL (seperti tanda kutip tunggal `'`, titik koma `;`, atau tanda hubung `--`) pada kotak pencarian untuk melihat apakah aplikasi memunculkan pesan *error* database. Hal ini memberi petunjuk bahwa sistem rentan.

3. Exploit

Setelah memastikan kerentanan, penyerang merancang kueri SQL penuh (misalnya menggunakan perintah `UNION SELECT`) untuk mengekstrak data dari tabel pengguna atau tabel transaksi secara langsung dari form pencarian.

Mitigasi

Cara Mitigasi

- Menggunakan *Parameterized Queries* (Prepared Statements) di level *backend*.
- Menerapkan validasi input yang ketat (*allowlisting*) dan melarang karakter khusus.

Kenapa Mitigasi Mengurangi Risk

Parameterized queries memisahkan antara "kode logis" dan "data". Jika pengguna memasukkan *script* berbahaya seperti `' OR 1=1`, database hanya akan membacanya murni sebagai *string* kata yang sedang dicari, sehingga menggagalkan eksekusi *logic* berbahayanya.

Pendekatan	*Address*

Ancaman 2: Penyerang memasukkan script berbahaya (Reflected XSS)

STRIDE Analysis:

STRIDE	*Spoofing, Tampering, Information Disclosure, Elevation of Privilege*

Bagaimana Attack dapat Terjadi

Penyerang tidak menargetkan server secara langsung, melainkan pengguna lain. Penyerang menyisipkan *script* berbahaya (seperti kode JavaScript `<script>`) ke dalam URL hasil pencarian e-commerce. Penyerang kemudian mengirim URL tersebut ke korban. Ketika korban mengkliknya, *browser* korban akan mengeksekusi *script* tersebut karena aplikasi e-commerce memantulkan kembali input pencarian tersebut ke layar tanpa disanitasi.

Prasyarat (Prerequisite)

Aplikasi web mengambil input pencarian dari pengguna dan langsung menampilkannya kembali ke layar halaman (misalnya menampilkan teks: "Hasil pencarian untuk: [Input User]") tanpa melakukan *encoding* HTML.

Sumber Daya yang Dibutuhkan Penyerang

Pengetahuan dasar tentang HTML dan JavaScript, serta sarana untuk mendistribusikan tautan (seperti email, forum, atau *chat*).

Konsekuensi / Dampak

Scope	Impact	Likelihood
Confidentiality / Access Control	*Script* penyerang dapat mencuri *Session Cookies* milik korban, membajak sesi login korban, atau melakukan tindakan transaksi seolah-olah penyerang adalah korban.	Probable

Mapping Standard References:

CAPEC ID	*CAPEC-591 Reflected XSS (Cross-Site Scripting)*

Kenapa Berkaitan

Ancaman ini cocok karena mengeksploitasi kelemahan di mana aplikasi menerima input *HTTP request* (dari pencarian) dan memantulkannya kembali (*reflect*) ke pengguna dalam respons *HTTP* secara langsung tanpa validasi.

Alur Eksekusi Serangan

1. Explore (Reconnaissance)

Penyerang mencari parameter URL atau input formulir yang nilainya akan dikembalikan (dipantulkan/*reflected*) secara langsung ke dalam respons halaman HTML target tanpa melalui proses sanitasi yang memadai.

2. Experiment

Penyerang mengetikkan tag HTML dasar (seperti `<h1>test</h1>`) di kolom pencarian. Jika tulisan "test" muncul dalam format *heading* besar, aplikasi terbukti rentan karena mengeksekusi tag tersebut.

3. Exploit

Penyerang menyusun URL *phishing* berisi *script* pencuri *cookie* (misal `?search=<script>mencuri_cookie()</script>`), lalu mengirimkan *link* tersebut ke pengguna aplikasi lain lewat *email* palsu bertopeng promo.

Mitigasi

Cara Mitigasi

- Menerapkan *Context-Aware Output Encoding* sebelum merender data ke *browser*. Semua karakter khusus (seperti `<` dan `>`) diubah menjadi entitas HTML (`<` dan `>`).
- Menerapkan *Content Security Policy* (CSP) pada *header* HTTP.

Kenapa Mitigasi Mengurangi Risk

Output Encoding memastikan bahwa *browser* memperlakukan input pengguna murni sebagai teks yang harus ditampilkan secara visual, bukan sebagai kode *executable* yang harus dijalankan. CSP secara aktif memblokir *script* yang tidak berasal dari sumber resmi (*inline scripts*).

Pendekatan	*Address*

Ancaman 3: Denial of Service melalui QueryPencarian Berat

STRIDE Analysis:

STRIDE	*Denial of Service*

Bagaimana Attack dapat Terjadi

Penyerang secara sengaja mengirimkan kueri pencarian yang sangat kompleks, sangat panjang, atau diformat untuk memakan waktu pemrosesan database terlama secara berulang-ulang. Hal ini menyebabkan aplikasi kehabisan memori atau koneksi (*thread exhaustion*), sehingga lumpuh dan tidak bisa diakses pengguna lain.

Prasyarat (Prerequisite)

Sistem tidak membatasi panjang karakter *input search*, tidak memiliki *rate limiting*, dan gagal menetapkan *timeout* untuk pemrosesan kueri database.

Sumber Daya yang Dibutuhkan Penyerang

Skrip otomatis atau bot (seperti Python *script* atau Apache JMeter) untuk mengirim permintaan HTTP bervolume berat secara masif.

Konsekuensi / Dampak

Scope	Impact	Likelihood
Availability	*Server downtime*, layanan e-commerce berjalan sangat lambat, atau mati total sehingga pengguna asli tidak bisa berbelanja.	Probable

Mapping Standard References:

CAPEC ID	*CAPEC-469 HTTP DoS / Resource Depletion*

Kenapa Berkaitan

Tujuan utama ancaman ini adalah menghabiskan ketersediaan sumber daya server (*resource depletion*) dengan membanjiri sistem (flooding) pada tingkat aplikasi (lapisan HTTP), bukan tingkat jaringan.

Alur Eksekusi Serangan

1. Explore (Reconnaissance)

Penyerang menganalisis infrastruktur aplikasi web untuk menemukan fungsi atau titik ujung (*endpoints*) HTTP spesifik yang memakan banyak memori, CPU, atau membutuhkan waktu koneksi database yang lama untuk merespons.

2. Experiment

Penyerang mengirimkan satu atau beberapa permintaan HTTP yang dirancang secara khusus (misalnya dengan ukuran *payload* berlebih atau parameter yang kompleks) untuk mengevaluasi apakah respons server dapat diperlambat secara signifikan.

3. Exploit

Penyerang menggunakan skrip, bot, atau perangkat otomasi untuk mengirim rentetan permintaan HTTP berat tersebut secara terus-menerus. Hal ini menguras habis *pool thread* koneksi, CPU, atau memori memonopoli server, yang berujung pada DoS bagi pengguna yang sah.

Mitigasi

Cara Mitigasi

- Menerapkan *Rate Limiting* (pembatasan *request* berulang dari IP yang sama).
- Membatasi jumlah maksimum karakter pada *input* pencarian (misal maksimal 100 karakter).
- Menerapkan *Query Timeout* pada database (membatalkan pencarian yang memakan waktu lebih dari 5 detik).

Kenapa Mitigasi Mengurangi Risk

Pembatasan *input* dan *rate limiting* mencekik laju serangan secara langsung di pintu gerbang API sebelum mencapai pemrosesan berat. *Query Timeout* bertindak sebagai sekering pengaman: jika server mulai terbebani oleh satu *request*, ia akan memotong proses tersebut agar sisa server tetap hidup.

Pendekatan	*Address*

C. Fitur: Promo

Nama Fitur	Promo
Deskripsi	Fitur dalam aplikasi e-commerce yang mengelola distribusi pesan diskon dan klaim kupon promosi.
Aktor Terkait	Sales / Admin / User / Penyerang

Ancaman 1: Akun Palsu Mengirim Pesan Phishing Promo

STRIDE Analysis:

STRIDE	*Spoofing, Information Disclosure*

Bagaimana Attack dapat Terjadi

Penyerang membuat akun di e-commerce atau aplikasi perpesanan yang terkait, kemudian mengganti nama dan foto profilnya agar menyerupai akun resmi Admin atau Tim Sales. Mereka mengirimkan pesan "Selamat Anda mendapatkan Promo!" kepada pengguna lain yang berisi tautan phishing palsu untuk mencuri kredensial atau data kartu kredit.

Prasyarat (Prerequisite)

- Aplikasi tidak memiliki pembatasan penggunaan nama (*username*) tertentu.
- Platform belum memiliki mekanisme verifikasi visual (seperti centang biru/badge resmi) yang jelas untuk membedakan akun organisasi asli dan akun biasa.

Sumber Daya yang Dibutuhkan Penyerang

Akun biasa yang diretas atau baru dibuat, pemahaman dasar tentang *Social Engineering*, dan situs phishing replika.

Konsekuensi / Dampak

Scope	Impact	Likelihood
Confidentiality	Korban tertipu dan memberikan data login atau nomor kartu kredit ke situs palsu. Reputasi platform menurun akibat hilangnya kepercayaan pengguna.	Likely

Mapping Standard References:

CAPEC ID	*CAPEC-151 Identity Spoofing*

Kenapa Berkaitan

Ancaman ini sepenuhnya mengandalkan manipulasi identitas (*spoofing*) untuk memanipulasi persepsi korban agar percaya bahwa ia berinteraksi dengan entitas resmi (*trusted entity*).

Alur Eksekusi Serangan

1. Explore (Reconnaissance)

Penyerang mengumpulkan informasi mengenai entitas target yang sah (seperti gaya komunikasi, logo, atau nama pejabat/admin resmi) untuk merancang identitas palsu yang meyakinkan.

2. Experiment

Penyerang membuat identitas palsu tersebut dan mungkin mengirimkan beberapa pesan pengujian berskala kecil untuk mengevaluasi apakah sistem memblokirnya atau apakah korban memberikan respons yang diharapkan.

3. Exploit

Penyerang meluncurkan serangan secara penuh dengan menggunakan identitas yang dipalsukan untuk menipu korban agar mengungkapkan informasi sensitif, memberikan akses ke sistem, atau melakukan tindakan yang merugikan.

Mitigasi

Cara Mitigasi

- Mengimplementasikan label "Official Store" atau *Verified Badge* yang dikontrol penuh oleh sistem.
- Memblokir pendaftaran username yang mengandung kata kunci "Admin", "Official", "Support".

Kenapa Mitigasi Mengurangi Risk

Pemberian lencana resmi memberikan indikator visual yang mustahil dipalsukan, secara drastis mengurangi probabilitas korban percaya pada akun penipu.

Pendekatan	*Transfer to User*

Ancaman 2: User Spam / Penyerangan Bot pada Fitur Promo

STRIDE Analysis:

STRIDE	*Denial of Service*

Bagaimana Attack dapat Terjadi

Sesaat setelah promo besar diluncurkan (seperti Flash Sale), user resmi atau bot otomatis membombardir *endpoint* klaim promo dengan ribuan permintaan secara simultan. Tujuannya adalah mendapatkan promo.

Prasyarat (Prerequisite)

- Ketiadaan alat anti-bot (seperti CAPTCHA) pada *endpoint* transaksi promo.
- Tidak adanya pembatasan frekuensi permintaan (*Rate Limiting*) per pengguna atau IP.

Sumber Daya yang Dibutuhkan Penyerang

Skrip otomatis, aplikasi otomasi API (Postman Runner, Curl), atau jaringan perangkat (*botnet*).

Konsekuensi / Dampak

Scope	Impact	Likelihood
Availability	Server berjalan lambat atau *down*.	Likely

Mapping Standard References:

CAPEC ID	*CAPEC-125 Flooding*

Kenapa Berkaitan

Serangan ini difokuskan pada pengiriman rentetan permintaan (request) API ke sistem dalam jumlah yang luar biasa banyak untuk membebani kapasitas pemrosesan hingga layanan terdegradasi.

Alur Eksekusi Serangan

1. Explore (Reconnaissance)

Penyerang mengidentifikasi target jaringan atau layanan aplikasi, serta mencoba memperkirakan kapasitas *bandwidth* atau daya komputasi dari sistem target tersebut.

2. Experiment

Penyerang dapat mengirimkan paket uji coba dalam jumlah kecil untuk mengamati bagaimana mekanisme pemrosesan target bereaksi terhadap lonjakan lalu lintas yang tidak wajar.

3. Exploit

Penyerang mengeksekusi serangan dengan flooding target menggunakan volume paket data atau *request* layanan yang sangat besar secara serentak, menyebabkan DoS bagi pengguna yang sah.

Mitigasi

Cara Mitigasi

- Implementasi *Rate Limiting* di tingkat API Gateway.
- Menambahkan tantangan CAPTCHA saat proses klaim kupon promo.
- Scale up Server

Kenapa Mitigasi Mengurangi Risk

CAPTCHA efektif menggagalkan interaksi berbasis bot karena membutuhkan pengenalan visual manusia. *Rate limiting* menahan laju serangan sehingga server tidak kehabisan *resource*. Untuk menangani lonjakan user asli, scale up server memungkinkan untuk menangani lebih banyak user dalam waktu bersamaan

Pendekatan	*Accept*

D. Fitur: Login / Register

Nama Fitur	Login / Register
Deskripsi	Pintu masuk autentikasi dan pendaftaran akun pengguna ke dalam sistem e-commerce.
Aktor Terkait	User / Admin / Penyerang

Ancaman 1: SQL Injection pada Input Login/Register

STRIDE Analysis:

STRIDE	*Spoofing, Information Disclosure, Elevation of Privilege*

Bagaimana Attack dapat Terjadi

Penyerang memasukkan perintah SQL berbahaya ke dalam kotak input username atau kata sandi. Karena aplikasi langsung menggabungkan input tersebut ke dalam kueri autentikasi, penyerang bisa masuk ke akun pengguna lain atau admin tanpa perlu mengetahui kata sandi yang sebenarnya

Prasyarat (Prerequisite)

- Aplikasi gagal memvalidasi atau memfilter karakter dari input form otentikasi.
- Server tidak menggunakan *parameterized queries* saat mencocokkan kredensial di database.

Sumber Daya yang Dibutuhkan Penyerang

Browser web standar atau *tools intercept* (Burp Suite).

Konsekuensi / Dampak

Scope	Impact	Likelihood

Confidentiality / Integrity	Attacker berhasil *bypass* mekanisme login, mengakses akun pengguna sah, atau mendapatkan hak akses Admin.	Likely

Mapping Standard References:

CAPEC ID	*CAPEC-66 SQL Injection*

Kenapa Berkaitan

Penyerang menyuntikkan muatan kode SQL melalui input klien yang kemudian dieksekusi oleh database target.

Alur Eksekusi Serangan

1. Explore (Reconnaissance)

Penyerang memetakan (spidering) situs web untuk menemukan semua titik masuk (*entry points*) yang mengumpulkan input dari pengguna, seperti formulir pencarian, parameter URL, atau header HTTP tertentu.

2. Experiment

Penyerang mencoba memasukkan karakter khusus SQL (seperti tanda kutip tunggal `'`, titik koma `;`, atau tanda hubung `--`) pada kotak pencarian untuk melihat apakah aplikasi memunculkan pesan *error* database. Hal ini memberi petunjuk bahwa sistem rentan.

3. Exploit

Penyerang merancang muatan kueri SQL khusus yang dapat memanipulasi logika *backend* (misalnya membuat pernyataan kueri selalu bernilai `TRUE`), sehingga penyerang berhasil melewati validasi keamanan dan mengeksekusi aksi di database.

Mitigasi

Cara Mitigasi

- Menggunakan *Parameterized Queries* (Prepared Statements) di level *backend*.
- Menerapkan validasi input yang ketat (*allowlisting*) dan melarang karakter khusus.

Kenapa Mitigasi Mengurangi Risk

Parameterized queries memisahkan antara "kode logis" dan "data". Jika pengguna memasukkan *script* berbahaya seperti `' OR 1=1`, database hanya akan membacanya murni sebagai *string* kata yang sedang dicari, sehingga menggagalkan eksekusi *logic* berbahayanya.

Pendekatan	*Address*

Ancaman 2: Memaksa Masuk ke Akun (Brute Force)

STRIDE Analysis:

STRIDE	*Spoofing, Elevation of Privilege*

Bagaimana Attack dapat Terjadi

Penyerang menggunakan skrip otomatis untuk secara terus-menerus mencoba menebak kombinasi username dan password yang valid. Serangan ini sering memanfaatkan daftar *password* yang bocor dari situs lain (*credential stuffing*).

Prasyarat (Prerequisite)

- Aplikasi tidak membatasi jumlah percobaan *login* yang gagal.
- Tidak ada perlindungan *rate limiting* atau verifikasi tambahan (seperti OTP/MFA).

Sumber Daya yang Dibutuhkan Penyerang

Daftar kombinasi username/password (*wordlists*) dan *tools* otomatisasi *brute force* (seperti Hydra, Burp Intruder).

Konsekuensi / Dampak

Scope	Impact	Likelihood
Confidentiality / Authorization	*Penyerang berhasil membobol masuk ke dalam akun korban, mencuri saldo/data, dan menyamar sebagai pengguna yang sah.*	Likely

Mapping Standard References:

CAPEC ID	*CAPEC-112 Brute Force*

Kenapa Berkaitan

Serangan ini didasarkan pada metode coba-coba (*trial and error*) yang sistematis untuk menebak informasi rahasia (kata sandi) dengan mengandalkan kecepatan komputasi.

Alur Eksekusi Serangan

1. Explore (Reconnaissance)

Penyerang menganalisis mekanisme otentikasi target untuk memahami bagaimana kredensial divalidasi dan apakah sistem memperbolehkan pengujian paralel berkecepatan tinggi.

2. Experiment

Penyerang mengumpulkan intelijen (seperti kebijakan kata sandi, tanggal lahir pengguna, atau algoritma hashing) untuk mempersempit ruang pencarian (*search space*) kata sandi menjadi lebih kecil.

3. Exploit

Penyerang menjalankan *tools* otomatis yang secara berulang kali mengirimkan tebakan kredensial ke server tanpa henti hingga ditemukan kombinasi yang berhasil masuk dan diakui oleh sistem.

Mitigasi

Cara Mitigasi

- Menerapkan fitur *Account Lockout* sementara (misal: blokir 15 menit setelah 5 kali gagal). Menerapkan *Multi-Factor Authentication* (MFA) / OTP.

Kenapa Mitigasi Mengurangi Risk

Account lockout merusak efektivitas metode coba-coba karena prosesnya menjadi terlalu lama dan tidak praktis. MFA memastikan bahwa penyerang tetap gagal masuk walaupun berhasil menebak kata sandi, karena mereka tidak memegang perangkat HP fisik pengguna.

Pendekatan	*Address*

Ancaman 3: Memanipulasi User State (Session / Cookie)

STRIDE Analysis:

STRIDE	*Spoofing, Tampering, Elevation of Privilege*

Bagaimana Attack dapat Terjadi

Penyerang yang sudah berhasil *login* memodifikasi data sesi (*user state*) yang disimpan di *browser* mereka (misalnya *cookie* atau *hidden parameters*). Jika sistem menyimpan *role*

pengguna (seperti `role=user`) di dalam *cookie* tanpa enkripsi, penyerang bisa mengubahnya menjadi `role=admin`.

Prasyarat (Prerequisite)

Sistem menyimpan informasi otoritas atau *state* penting secara terbuka di sisi klien tanpa perlindungan kriptografis (seperti tanda tangan digital/HMAC).

Sumber Daya yang Dibutuhkan Penyerang

Browser Developer Tools atau *Cookie Editor* sederhana.

Konsekuensi / Dampak

Scope	Impact	Likelihood
Access Control	*Attacker dapat melakukan Elevation of Privilege menjadi administrator atau bertransaksi atas nama pengguna lain.*	Probable

Mapping Standard References:

CAPEC ID	*CAPEC-74 Manipulating User State*

Kenapa Berkaitan

Penyerang secara langsung merusak, mengubah, atau memalsukan struktur kontrol status (sesi) yang digunakan oleh aplikasi untuk melacak konteks pengguna.

Alur Eksekusi Serangan

1. Explore (Reconnaissance)

Penyerang mengidentifikasi di mana dan bagaimana aplikasi target mengelola pelacakan status pengguna, seperti mengamati pembuatan variabel *Cookie*, URL parameter, atau *Hidden Fields* di HTML.

2. Experiment

Penyerang mencoba memodifikasi isi *state* tersebut dan mengamati bagaimana aplikasi bereaksi atau beralih sesi.

3. Exploit

Penyerang menggunakan data *state* yang telah dimanipulasi dengan cermat untuk memaksa aplikasi memproses transaksi ilegal, melangkahi logika bisnis, atau meningkatkan hak akses ke tingkat sistem yang lebih tinggi.

Mitigasi

Cara Mitigasi

Simpan data kontrol status secara eksklusif di server (*Server-side sessions*). Jika menggunakan token *client-side* (seperti JWT), pastikan *payload*-nya ditandatangani secara kriptografis (*cryptographically signed*). tabase (membatalkan pencarian yang memakan waktu lebih dari 5 detik).

Kenapa Mitigasi Mengurangi Risk

Penyimpanan di sisi server mencegah penyerang menyentuh data sesi. Jika ditandatangani, setiap modifikasi pada *cookie* akan merusak integritas *signature*-nya, sehingga server akan langsung menolak sesi tersebut.

Pendekatan	*Address*

E. COD

Nama Fitur	Cash on Delivery
Deskripsi	Metode transaksi penyelesaian pembayaran saat barang telah tiba di tangan pengguna.
Aktor Terkait	User / Penyerang

Ancaman 1: Penggunaan Akun Palsu

STRIDE Analysis:

STRIDE	*Repudiation*

Bagaimana Attack dapat Terjadi

Penyerang membuat akun menggunakan identitas palsu (email sekali pakai, nomor HP sementara) untuk memesan barang berharga tinggi dengan metode COD. Saat kurir tiba, ia menolak pesanan atau kabur. Karena identitas aslinya tidak diketahui, sistem tidak bisa melacak atau menagih kerugian pada pelaku.

Prasyarat (Prerequisite)

Sistem registrasi e-commerce tidak memiliki verifikasi identitas (KYC) atau nomor telepon yang kuat.

Sumber Daya yang Dibutuhkan Penyerang

Layanan pembuat email/nomor telepon virtual gratis di internet.

Konsekuensi / Dampak

Scope	Impact	Likelihood
Financial	Kerugian biaya logistik (ongkos kirim retur) bagi *seller* maupun platform akibat penolakan paket.	Likely

Mapping Standard References:

CAPEC ID	*CAPEC-151 Identity Spoofing*

Kenapa Berkaitan

Serangan ini memanfaatkan pemalsuan identitas dari awal proses sehingga pelaku tidak memiliki ikatan tanggung jawab (*non-repudiation* gagal) dengan tindakan yang ia lakukan

Alur Eksekusi Serangan

1. Explore (Reconnaissance)

Penyerang mengumpulkan informasi mengenai entitas target yang sah (seperti gaya komunikasi, logo, atau nama pejabat/admin resmi) untuk merancang identitas palsu yang meyakinkan.

2. Experiment

Penyerang membuat identitas palsu tersebut dan mungkin mengirimkan beberapa pesan pengujian berskala kecil untuk mengevaluasi apakah sistem memblokirnya atau apakah korban memberikan respons yang diharapkan.

3. Exploit

Penyerang meluncurkan serangan secara penuh dengan menggunakan identitas yang dipalsukan untuk menipu korban agar mengungkapkan informasi sensitif, memberikan akses ke sistem, atau melakukan tindakan yang merugikan.

Mitigasi

Cara Mitigasi

Mewajibkan verifikasi OTP via nomor WhatsApp lokal yang sah. Menerapkan *device fingerprinting* untuk melacak perangkat yang mendaftar.

Kenapa Mitigasi Mengurangi Risk

Menghubungkan akun ke entitas nomor HP yang terdaftar memudahkan penegakan akuntabilitas. *Device fingerprinting* memastikan bahwa walau akun dipalsukan, perangkat ponsel aslinya akan di-*blacklist* oleh sistem.

Pendekatan	*Address*

Ancaman 2: Penggunaan Perangkat Bersama (Shared Device)

STRIDE Analysis:

STRIDE	*Repudiation*

Bagaimana Attack dapat Terjadi

Penyerang sengaja melakukan pemesanan COD palsu melalui komputer publik. Tujuannya adalah untuk menyangkal tindakannya dengan alibi "bukan saya yang memesan, IP dan alatnya bukan milik saya".

Prasyarat (Prerequisite)

- Aplikasi gagal mengikat sesi log masuk secara akurat ke aktivitas pengguna nyata (*session binding* yang lemah).

Sumber Daya yang Dibutuhkan Penyerang

Akses ke fasilitas komputer publik tanpa perlu keahlian teknis.

Konsekuensi / Dampak

Scope	Impact	Likelihood
Business	*E-commerce kesulitan menuntut pertanggungjawaban karena bukti digitalnya ambigu (berasal dari mesin publik).*	Plausible

Mapping Standard References:

CAPEC ID	*CAPEC-16 Leveraging Shared Resources*

Kenapa Berkaitan

Penyerang secara aktif memanfaatkan sifat *anonymous* dari lingkungan atau sistem sumber daya bersama (seperti komputer publik) untuk menyembunyikan identitas asli mereka.

Alur Eksekusi Serangan

1. Explore (Reconnaissance)

Penyerang mencari dan mengidentifikasi lingkungan jaringan atau perangkat fisik yang dapat diakses oleh banyak pengguna tanpa kontrol pengawasan ketat.

2. Experiment

Penyerang menguji apakah aktivitas pada sumber daya bersama tersebut dilacak secara spesifik ke individu, atau hanya dilacak sebagai "pengguna *guest*".

3. Exploit

Penyerang memanfaatkan lingkungan bersama ini untuk melakukan aktivitas ilegal atau menyembunyikan jejak mereka di antara kerumunan lalu lintas *user* lainnya, sehingga identitas mereka terlindungi.

Mitigasi

Cara Mitigasi

- Menggunakan fitur *auto-logout* sesaat setelah tidak ada interaksi.
- Mengirimkan notifikasi otentikasi konfirmasi (seperti *push notification* ke HP utama) saat proses *checkout* dilakukan dari perangkat baru/publik.

Kenapa Mitigasi Mengurangi Risk

Konfirmasi ke perangkat utama mencegah pesanan diproses hanya dari sesi publik, serta memaksa pengguna yang sah (atau penyerang) untuk memverifikasi tindakan tersebut secara sadar.

Pendekatan	*Address*

Ancaman 3: Exploit Weak Logging System

STRIDE Analysis:

STRIDE	*Repudiation*

Bagaimana Attack dapat Terjadi

enyerang mengeksploitasi kelalaian arsitektur sistem yang tidak memiliki mekanisme pencatatan (*logging*) aktivitas transaksi yang kuat. Penyerang membuat pesanan COD dan

menolaknya saat tiba. Karena sistem tidak merekam detail forensik saat pesanan dibuat, administrator e-commerce sama sekali tidak memiliki bukti digital hukum (log) untuk mengonfrontasi pelaku, sehingga penyangkalan pelaku tidak bisa dibantah.

Prasyarat (Prerequisite)

Sistem aplikasi gagal merekam informasi kritis di *backend* seperti alamat IP pengakses, *timestamps* (waktu persis), detail perangkat (*device info*), dan riwayat audit (*audit trails*).

Sumber Daya yang Dibutuhkan Penyerang

Hanya sebuah akun (baik yang sah maupun palsu) dan koneksi internet. Kerentanan berada murni pada kegagalan desain aplikasi itu sendiri.

Konsekuensi / Dampak

Scope	Impact	Likelihood
Business	Ketidakmampuan total dari pihak aplikasi untuk membuktikan kebenaran tindakan (*prove user actions*), yang berpotensi memicu kerugian finansial, risiko hukum, dan hilangnya akuntabilitas sistem	Probable

Mapping Standard References:

CAPEC ID	*OWASP A09 Security Logging and Monitoring Failures*

Kenapa Berkaitan

Ancaman ini mengakar secara langsung pada kelemahan infrastruktur pemantauan (*monitoring*), di mana ketiadaan *log* transaksi vital memberikan kebebasan mutlak bagi aktor jahat untuk berbohong tanpa takut dibuktikan salah

Alur Eksekusi Serangan

1. Explore (Reconnaissance)

Penyerang menganalisis atau menduga bahwa sistem tidak memelihara log audit transaksi secara rinci. Mereka mencari kelemahan seperti tidak adanya email verifikasi pesanan atau pencatatan IP.

2. Experiment

Penyerang berinteraksi secara normal namun mengamati apakah aktivitas mereka meninggalkan jejak yang bisa diverifikasi (*audit trails*) oleh administrator.

3. Exploit

Penyerang menyelesaikan proses pembayaran COD. Ketika sengketa (*dispute*) diangkat karena barang ditolak, penyerang menyangkal pemesanan tersebut. Akibat *logging* yang buruk, sistem gagal menyediakan bukti forensik digital (*timestamp*/IP), menjadikan proses resolusi memihak pada penyerang.

Mitigasi

Cara Mitigasi

Mengimplementasikan mekanisme *logging* keamanan yang komprehensif (wajib mencatat alamat IP, *timestamps*, metadata perangkat, serta aktivitas *user*). Menggunakan OTP *confirmation* ganda sesaat sebelum transaksi COD disahkan.

Kenapa Mitigasi Mengurangi Risk

Log komprehensif bertindak sebagai bukti audit yang tidak bisa dimanipulasi (*tamper-proof*), memastikan arsitektur *non-repudiation* berjalan dengan baik. Konfirmasi OTP meninggalkan jejak pengiriman pesan SMS ke operator seluler, yang bertindak sebagai bukti solid bahwa pengguna di perangkat tersebut sadar akan tindakannya.

Pendekatan	*Address*

BAB V - Trade-off Analysis

Tabel Trade-off per Fitur

Trade-off analysis dilakukan untuk mengevaluasi keseimbangan antara keamanan, performa, dan kemudahan penggunaan (usability) terhadap setiap mitigasi yang diterapkan pada Sistem Transaksi E-Commerce. Setiap keputusan mitigasi mempertimbangkan tingkat keparahan ancaman, biaya implementasi, serta dampaknya terhadap pengalaman pengguna. Analisis ini mencakup lima fitur utama yang telah diidentifikasi pada tahap threat modelling, yaitu Payment, Search Bar, Promo, Login/Register, dan COD.

5.1 Fitur Payment

Threats	Impact	Mitigate Approach	Explaination
Manipulasi Status Kupon	Attacker dapat menggunakan Kupon promo berkali kali hingga harga barang menjadi sangat murah bahkan 0	Address	Mitigasi nya adalah dengan cara menambahkan mekanisme soft locking pada kupon yang dibarengi dengan mekanisme time to live.
Eksploitasi Race Condition	Attacker dapat menggunakan saldo yang dimiliki untuk membeli barang lebih dari jumlah yang sebenarnya	Address	Mitigasi nya adalah dengan mengimplementasikan mekanisme database locking sehingga setiap permintaan yang masuk akan diproses satu per satu. Selain itu juga ada mekanisme idempotency key yang membuat tiap transaksi memiliki unique id nya sendiri.
Bypass Validasi Client Side	Attacker bisa merubah harga barang, stok barang, bahkan logika serta parameter sensitif lain nya melalui intercepting	Address	Mitigasi yang pertama adalah menerapkan prinsip never trust the client. Kedua adalah melakukan sanitasi sehingga code berbahaya tidak gampang masuk, dan yang terakhir adalah memastikan segala perhitungan yang menyangkut harga barang, kupon, dll menggunakan data internal, bukan dari request client.

5.2 Fitur Search Bar

Threats	Impact	Mitigate Approach	Explaination
SQL Injection	Dapat memanipulasi query Database. Sehingga attacker bisa melihat data sensitif, mengubah isi database, atau bahkan menghapus table.	Address	Address karena mitigasinya mudah dan murah, yaitu menerapkan Parameterized Queries (memaksa database untuk melihat input user sebagai teks biasa, bukan perintah/query).
Cross-Site Scripting	Attacker bisa mencuri cookies atau session token pengguna, mengubah tampilan halaman, atau mengarahkan user ke situs web phishing.	Address	Address karena mitigasinya mudah dan murah, yaitu menerapkan Output Encoding (mengubah karakter yang biasa dipakai di script attacker menjadit teks biasa).
DOS	Attacker membanjiri search bar dengan ribuan permintaan pencarian dalam waktu singkat. Sehingga server down.	Address	Address karena mitigasinya mudah dan murah, yaitu menerapkan Rate Limiting, Query Timeouts, dan membatasi panjang maksimal karakter yang bisa diinput.

5.3 Fitur Promo

Threats	Impact	Mitigate Approach	Explaination
Identity Spoofing	Dapat menyebabkan kebocoran data sensitif, pengambil alihan akun dan dapat menimbulkan hilangnya kepercayaan pengguna	Transfers the risk	Transfer risk ke user sendiri dengan memberikan edukasi ke user sehingga memiliki pengetahuan mengenai link phisink.
Request Spamming	Sistem menjadi lambat atau down karena beban bot yang berlebihan	Accept	Accept the risk karena untuk menangani user yang banyak ini diperlukan biaya yang mahal untuk mengupgrade server.

5.4 Fitur Login/Register

Threats	Impact	Mitigate Approach	Explaination
SQL Injection	Membuat attacker dapat bypass mekanisme login dan mengakses akun pengguna lain	Address	Mitigasinya tidak terlalu mahal karena sudah tersedia framework modern seperti input validation, ORM, dsb meskipun memang tingkat kesulitan lebih tinggi.
Brute Force	Masuk ke akun orang lain dan melakukan tindakan yang mengatasnamakan orang tersebut. Jika berhasil brute force ke akun admin, bisa mendapatkan privilege yang tidak seharusnya. Bisa membuat server down juga karena termasuk spam request.	Address	Mitigasinya tidak memakan budget yang tinggi seperti rate limiting dan account lockout. Jika ada budget lebih, bisa menggunakan layanan tambahan seperti Cloudflare, CAPTCHA premium, dll.
Memanipulasi User State	Attacker dapat menaikkan hak istimewa (Elevation of Privilege) menjadi administrator atau bertransaksi atas nama pengguna lain.	Address	Mitigasinya cukup murah yaitu simpan data kontrol status secara eksklusif di server (Server-side sessions). Jika menggunakan token client-side (seperti JWT), pastikan payload-nya ditandatangani secara kriptografis (cryptographically signed).

5.5 Fitur Cash on Delivery

Threats	Impact	Mitigate Approach	Explaination
Use Fake Account	Penyerang membuat akun fiktif menggunakan identitas palsu untuk melakukan transaksi COD. Dampaknya serius karena menyebabkan transaksi penipuan, kerugian finansial bagi perusahaan, dan	Address	Sistem harus diperbaiki dengan menerapkan verifikasi identitas yang lebih kuat seperti verifikasi telepon berbasis OTP, sistem email terverifikasi, dan prosedur KYC untuk transaksi berisiko tinggi. Selain itu, terapkan otentikasi

	menurunnya kepercayaan pengguna		multi-faktor (MFA), device fingerprinting, dan analisis perilaku.
Use Shared Device	Penyerang menggunakan perangkat publik atau perangkat bersama untuk melakukan pesanan COD. Dampaknya signifikan karena menyulitkan identifikasi pihak yang bertanggung jawab, meningkatkan risiko penipuan, dan mengurangi akuntabilitas dalam sistem	Address	Sistem perlu diperbaiki dengan mengimplementasikan teknik pengikatan perangkat (device binding) dan memelihara log informasi perangkat, alamat IP, serta sesi pengguna. Mekanisme manajemen sesi seperti automatic logout, peringatan login, dan deteksi anomali juga harus ditegakkan.
Exploit Weak Logging System	Penyerang memanfaatkan kelemahan atau ketiadaan mekanisme logging dalam sistem. Dampaknya serius karena sistem tidak mampu membuktikan tindakan pengguna, yang dapat mengarah pada kerugian finansial, peningkatan risiko penipuan, dan potensi masalah hukum.	Address	Sistem harus diperbaiki dengan menerapkan mekanisme logging yang komprehensif, termasuk merekam alamat IP, timestamps, informasi perangkat, dan aktivitas pengguna secara detail. Audit trails harus dipelihara, serta mekanisme verifikasi OTP dan konfirmasi transaksi perlu ditambahkan untuk memperkuat non-repudiation

Kesimpulan Trade-off

Dari seluruh mitigasi yang dianalisis, sebagian besar ancaman pada Sistem Transaksi E-Commerce ditangani dengan keputusan Address karena biaya implementasinya proporsional terhadap tingkat kekritisan ancaman. Keseimbangan antara keamanan dan kemudahan pengguna dijaga dengan mengutamakan validasi di sisi server tanpa sepenuhnya mengorbankan pengalaman pengguna, seperti pada penerapan rate limiting dengan threshold yang dapat dikonfigurasi dan CAPTCHA yang hanya aktif saat terdeteksi aktivitas mencurigakan.

Terdapat satu ancaman yang secara eksplisit diterima (Accept), yaitu Request Spamming pada fitur Promo, dengan pertimbangan bahwa biaya mitigasi teknis berupa peningkatan kapasitas server tidak

sebanding dengan anggaran yang tersedia saat ini. Sementara itu, ancaman Identity Spoofing pada fitur Promo dialihkan risikonya (Transfer Risk) melalui edukasi pengguna, mengingat sifat ancaman yang sangat bergantung pada perilaku pengguna dan berada di luar kendali langsung sistem.

Secara keseluruhan, prioritas keamanan tertinggi diberikan pada fitur Payment dan Login/Register karena kedua fitur tersebut memiliki dampak finansial dan reputasional yang paling besar apabila terjadi eksploitasi.

BAB VI — Kesimpulan dan Saran

6.1 Peta Ancaman per Fitur (Overview)

Fitur	Ancaman	STRIDE	CAPEC	Pendekatan
Payment	Manipulasi status kupon	T	CAPEC-94	Address
	Eksploitasi race condition	T, DoS	CAPEC-26	Address
	Bypass validasi client side	T	CAPEC-153 | CAPEC-207	Address
Search Bar	SQL Injection	T, I, E	CAPEC-66	Address
	XSS	S, T, I, E	CAPEC-591	Address
	DoS	DoS	CAPEC-469	Address
Promo	Identity Spoofing	S,I	CAPEC-151	Transfer to Users
	Request Spamming (saat flash sale)	DoS	CAPEC-125	Accept
Login and Register	SQL Injenction	S, I, E	CAPEC-66	Address
	Brute Force	S, E	CAPEC-112	Address
	Memanipulasi User State	T, E	CAPEC-93	Address
COD	Mengunakan akun palsu (order fiktif)	S, R	CAPEC-151	Address
	Use Shared Device	S, R	CAPEC-16	Address
	Exploit Weak Logging System	T, R, I	CAPEC-268 | CAPEC-93	Address

6.2 Kesimpulan

Berdasarkan hasil pemodelan ancaman menggunakan kerangka kerja STRIDE dan taksonomi CAPEC pada lima fitur utama aplikasi e-commerce, dapat disimpulkan bahwa titik kerentanan paling kritis terletak pada tingginya ketergantungan sistem terhadap validasi di sisi klien serta kegagalan sanitasi input, yang membuka celah bagi serangan manipulasi data (Tampering) seperti interupsi kupon via proxy, bypass harga, SQL Injection, dan Reflected XSS. Selain itu, ketiadaan mekanisme penguncian data transaksional memicu eksploitasi Race Condition yang merugikan logika finansial, sementara kelemahan sistem pencatatan log dan penggunaan akun palsu mempertinggi risiko penyangkalan transaksi (Repudiation) pada fitur COD oleh karena itu penguatan arsitektur keamanan mutlak dilakukan dengan menggeser seluruh validasi logika bisnis ke sisi server menerapkan Prepared Statements, menggunakan mekanisme Data Locking, serta memperketat Audit Trail guna mencapai keseimbangan optimal antara perlindungan aset kritis, performa sistem, dan kenyamanan pengguna.

6.3 Saran

Guna memitigasi potensi ancaman yang telah dipetakan dan memperkuat postur keamanan aplikasi e-commerce ini secara menyeluruh, disarankan beberapa tindakan korektif berikut:

1. Implementasi Arsitektur Zero-Trust Input di Sisi Server

- Validasi Berlapis: Wajibkan Strict Server-Side Validation untuk seluruh parameter transaksional. Backend harus memposisikan diri sebagai Single Source of Truth misalnya klien hanya diizinkan mengirim ProductID dan Quantity sedangkan nominal harga wajib ditarik langsung dari database internal.
- Keamanan Kueri & Output: Ganti semua kueri SQL dinamis dengan Parameterized Queries atau Prepared Statements untuk menutup celah SQLi disarakan untuk menggunakan Context-Aware Output Encoding serta pasang header Content Security Policy (CSP) yang ketat untuk menangkal eksekusi skrip XSS.

2. Penguatan Proteksi Konkurensi dan Arsitektur Trafik

- Mekanisme Data Locking: Terapkan Pessimistic Locking pada fungsi database yang memproses pengurangan saldo atau kuota kupon sensitif, serta integrasikan Message Broker (seperti RabbitMQ atau Kafka) dengan metode antrean FIFO (First-In-First-Out) untuk meredam serangan Race Condition.
- Manajemen Bot dan Anti-Spam: Terapkan pembatasan laju trafik (Rate Limiting) menggunakan API Gateway, batasi waktu tunggu HTTP session (Query Timeout), dan pasang CAPTCHA/OTP interaktif pada endpoint login serta klaim promo guna menyaring banjir request otomatis oleh bot.

3. Peningkatan Autentikasi dan Akuntabilitas Catatan (Anti-Repudiation)

- Validasi Identitas COD: Perketat pendaftaran akun dengan validasi nomor telepon berbasis OTP (One-Time Password) atau integrasikan verifikasi identitas khusus untuk pengguna yang memilih metode pembayaran COD guna menekan angka order fiktif.
- Audit Trail yang Aman: Implementasikan pencatatan log terpusat yang bersifat Read-Only atau Append-Only. Sebelum log ditulis, lakukan sanitasi terhadap karakter kontrol untuk mencegah serangan Log Forging serta hindari melihat data log menggunakan tools terminal yang dapat menginterpretasikan skrip eksekusi.

Referensi

OWASP Foundation. (2021). *OWASP Top 10:2021*. https://owasp.org/Top10/

MITRE Corporation. (n.d.). *Common Attack Pattern Enumeration and Classification (CAPEC)*. https://capec.mitre.org/

Shostack, A. (2014). *Threat Modeling: Designing for Security*. Wiley.

Microsoft. (n.d.). *The STRIDE Threat Model*. Microsoft Security Documentation.

Lampiran

Lampiran A — Trade-off Analysis (Excel)

Kelompok 3 - Threat Modelling TradeOff

Lampiran B — DFD (Gambar)

Data Flow Diagram